

# HIPAA Business Associate Agreement — Shyware SDK Operator Template

---

Published at <https://shyware.fyi/legal/privacy/dpia/dpa/hipaa-baa>

**Framing note:** This template is provided by Shyware (Licensor) for use by Operators (Licensees) who deploy the Shyware SDK in contexts that constitute a covered entity or business associate relationship under HIPAA. The Operator executes this agreement with each of its Covered Entity customers. Shyware is not a party to this agreement; Shyware is the PaaS protocol licensor whose structural guarantees the Operator relies on to satisfy its technical safeguard obligations as a Business Associate.

---

## Agreement Parties

| Party                          | Details                                                                        |
|--------------------------------|--------------------------------------------------------------------------------|
| <b>Covered Entity (CE)</b>     | REQUIRED_OPERATOR_INPUT — name, address, contact for HIPAA compliance          |
| <b>Business Associate (BA)</b> | REQUIRED_OPERATOR_INPUT — Operator name, address, contact for HIPAA compliance |
| <b>Effective Date</b>          | REQUIRED_OPERATOR_INPUT                                                        |

## Recitals

1. The Covered Entity is a covered entity as defined under the Health Insurance Portability and Accountability Act of 1996 (HIPAA), as amended by the Health Information Technology for Economic and Clinical Health Act (HITECH), and the regulations promulgated thereunder (collectively, the **HIPAA Rules**).
2. The Business Associate provides services to the Covered Entity that involve the creation, receipt, maintenance, or transmission of Protected Health Information (PHI), as defined in 45 CFR §160.103.
3. The Business Associate deploys the Shyware SDK (**shystore-v1** contract variant) as its primary storage layer for PHI. The Shyware SDK implements structural anonymity via the two-list invariant: PHI payload commitments (List 1) and identity records (List 2) are written to a BFT ABCI state machine in structurally disjoint partitions, with no join key ever materialised in canonical state. The SDK satisfies the HIPAA Technical Safeguards at 45 CFR §164.312 as enumerated in Section 1.6 below.
4. This Agreement is entered into to satisfy the requirements of 45 CFR §164.308, §164.310, §164.312, and §164.314.

## Definitions

Terms used but not defined herein have the meanings given in the HIPAA Rules. Key defined terms:

- **PHI:** Protected Health Information, including electronic PHI (ePHI), as defined at 45 CFR §160.103.
- **Breach:** Acquisition, access, use, or disclosure of PHI in a manner not permitted under the HIPAA Rules that compromises security or privacy, as defined at 45 CFR §164.402.
- **Shyware SDK:** The two-list invariant storage protocol licensed by Shyware (Licensor) under POPULIST-001 (patent pending), including the **shystore-v1** configuration and all associated runtime components (ABCI state machine, sealer layer, reconciling authority API).
- **Sealer Key:** The AES-256-GCM cryptographic key held by the Business Associate's key management service (AWS KMS, FIPS 140-3 L3) that encrypts PHI payloads before storage in the Shyware canonical layer.
- **Canonical State:** The BFT-replicated ledger state of the Shyware ABCI state machine, containing only structurally disjoint payload commitments (List 1) and identity hashes (List 2). Canonical state never contains plaintext PHI.

#### Permitted Uses and Disclosures by Business Associate

1. The Business Associate may use and disclose PHI as necessary to perform services for the Covered Entity as described in the underlying service agreement.
2. The Business Associate may use PHI for the proper management and administration of the Business Associate's operations, provided such use is necessary and the information is not further disclosed.
3. The Business Associate may disclose PHI for the proper management and administration of the Business Associate, provided: (a) the disclosure is required by law; or (b) the Business Associate obtains reasonable assurances from the recipient that the PHI will be held confidentially and used only for the purpose of disclosure.
4. The Business Associate shall not use or disclose PHI in any manner that would violate the HIPAA Privacy Rule if such use or disclosure were made by the Covered Entity.

#### Obligations and Activities of Business Associate

The Business Associate shall:

1. **Safeguards.** Implement and maintain appropriate administrative, physical, and technical safeguards to protect the confidentiality, integrity, and availability of ePHI as required by the HIPAA Security Rule (45 CFR Part 164, Subpart C), including the structural safeguards described in Section 1.6.
2. **Subcontractors.** Ensure that any subcontractors that create, receive, maintain, or transmit PHI on behalf of the Business Associate agree in writing to the same restrictions

and conditions as apply to the Business Associate under this Agreement. Required sub-processor BAAs: AWS (KMS, EC2, S3 Object Lock); CockroachDB HIPAA-eligible tier; Didit (identity context only, if biometric fallback is enabled in a PHI-covered deployment); EHR provider (e.g. Epic) for SMART on FHIR access.

3. **Breach notification.** Report to the Covered Entity any Breach of Unsecured PHI without unreasonable delay and no later than 60 calendar days after discovery (or such shorter period as required under any final rule amending 45 CFR §164.412). The report shall include: (a) identification of each individual whose PHI was involved; (b) description of the PHI involved; (c) description of what occurred; (d) steps taken to mitigate; (e) steps taken to prevent recurrence.
4. **Security incident reporting.** Report to the Covered Entity any Security Incident (as defined at 45 CFR §164.304) of which the Business Associate becomes aware, including attempted and successful unauthorised access, use, disclosure, modification, or destruction of PHI.
5. **Access.** Make PHI available to the Covered Entity or the individual as required by 45 CFR §164.524 (Right of Access) within 30 calendar days of request. The Shyware reconciling authority API supports per-participant, identity-gated retrieval (non-composable, non-enumerable) to fulfil individual access requests without exposing other participants' records.
6. **Amendment.** Make PHI available for amendment and incorporate any amendments in accordance with 45 CFR §164.526. Sealer-governed amendment is supported via `PATCH /api/store/secrets/:id` (replace-in-place; prior sealed version is overwritten; amendment is structurally isolated to the amending participant's record).
7. **Accounting of disclosures.** Make available to the Covered Entity the information required to provide an accounting of disclosures in accordance with 45 CFR §164.528. The authority-action audit surface (Claim 60 of POPULIST-001) records every reconciling operation with timestamp, authority identity, action type, and canonical hash commitment.
8. **HHS access.** Make internal practices, books, and records, including policies, procedures, and PHI, relating to the use and disclosure of PHI, available to HHS for the purpose of determining the Covered Entity's compliance.
9. **Minimum necessary.** Use or disclose only the minimum amount of PHI necessary to accomplish the intended purpose. The Shyware structural layer enforces minimum necessary at the architecture level: the non-composable reconcile API returns only the requesting participant's own record; no system-defined operation yields a join between List 1 and List 2.
10. **Mitigation.** Mitigate, to the extent practicable, any harmful effect known to the Business Associate of a use or disclosure of PHI in violation of this Agreement.

## Technical Safeguards (45 CFR §164.312) — Structural Implementation

The Business Associate represents that deployment of the Shyware SDK (`shystore-v1`) with the following configuration satisfies the HIPAA Technical Safeguards:

| Requirement                                                  | Implementation                                                                                                                                                                                                                                | Verification                                                                                 |
|--------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------|
| §164.312(a)(1) Access controls — unique user ID              | $H(\text{uid}  \text{scopingId})$ per submission; each participant's L2 identity hash is scoped per submission, preventing cross-submission correlation by canonical-state observers.                                                         | Stack 4/5/6 field-exclusivity assertions; no <code>identityHash</code> field in L1 responses |
| §164.312(a)(2)(iv) Access controls — encryption/decryption   | PHI sealed AES-256-GCM before any write; sealer key held in AWS KMS (FIPS 140-3 L3). Plaintext PHI never transmitted to or held by canonical state.                                                                                           | Sealer key deletion test (ERASURE section, run 26369476939)                                  |
| §164.312(a)(2) Access controls — minimum necessary           | No join key ever written between L1 (payload commitment) and L2 (identity hash). Reconcile API (Claim 56) is non-composable: returns only the requesting participant's own sealed record. Bulk-scan endpoints structurally absent (Claim 59). | GET <code>/api/store/secrets/all</code> → 403; Stack 4/5/6 RECONCILE isolation assertions    |
| §164.312(b) Audit controls                                   | Authority-action audit surface (Claim 60): every sealer-layer access operation logged with timestamp, authority identity, canonical hash commitment. Tamper-evident; signatures verifiable.                                                   | Stack 4 COUNT and PERIOD-CLOSE sections; HSM attestation verified                            |
| §164.312(c)(1) Integrity — alteration/destruction prevention | Count-match invariant $ L1(S)  =  L2(S) $ enforced atomically at ABCI validation layer. HSM-signed dual Merkle root period-close attestation (Claim 80) provides integrity proof. Post-close modification rejected.                           | Stack 4/5/6 PERIOD-CLOSE immutability assertion: second close → 409                          |
| §164.312(d) Person/entity authentication                     | Oracle-resistant identity binding (Claim 12): per-submission keypair generated on device; IDV provider attests identity without holding payload. Biometric re-derivation (HKDF-SHA256) for recovery.                                          | Stack 4/5/6 NEGATIVE unauthenticated → 401; write-only posture assertions                    |

| Requirement                             | Implementation                                                                                                                                                                             | Verification                                                                       |
|-----------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------|
| §164.312(e)(1)<br>Transmission security | All submission APIs require HTTPS (TLS enforced at Cloudflare ingress).<br>Write-only posture on hostile network (Claim 11) suppresses receipt retention.<br>No plaintext PHI transmitted. | Stack 4/5/6<br>unauthenticated submit<br>→ 401; posture assertions<br>in Stack 5/6 |

**Note on 2025/2026 HIPAA Security Rule NPRM:** The proposed rule (NPRM published 2025-01-06; final rule expected 2026) eliminates addressable/required distinctions. The shyware structural safeguards above satisfy all specifications under the proposed rule. The following are operational obligations outside the shyware structural layer that the Business Associate must separately implement: 72-hour breach notification to HHS; annual technology asset inventory; vulnerability scanning every 6 months; network segmentation documentation.

### Permitted Uses and Disclosures by Covered Entity

1. The Covered Entity shall notify the Business Associate of any limitation in the Covered Entity’s Notice of Privacy Practices that may affect the Business Associate’s use or disclosure of PHI.
2. The Covered Entity shall notify the Business Associate of any changes in, or revocation of, permission by an individual to use or disclose PHI, if such changes affect permitted or required uses and disclosures by the Business Associate.
3. The Covered Entity shall not request the Business Associate to use or disclose PHI in any manner that would not be permissible under the HIPAA Privacy Rule if done by the Covered Entity.

### Term and Termination

1. **Term.** This Agreement is effective as of the Effective Date and shall continue until termination of the underlying service agreement, unless terminated earlier under this Section.
2. **Termination for cause.** Either party may terminate this Agreement upon 30 days written notice if the other party materially breaches a provision of this Agreement and fails to cure within the notice period.
3. **Effect of termination — return or destruction.** Upon termination, the Business Associate shall return or destroy all PHI received from, or created on behalf of, the Covered Entity. The sealer-key deletion path (Claim 32: credential-free rescission) achieves cryptographic unrecoverability of sealed PHI payloads without requiring deletion of canonical-state records (which may be retained for BSA/audit purposes). Following sealer-key deletion,

the Business Associate shall certify in writing to the Covered Entity that all PHI has been destroyed or rendered cryptographically unrecoverable.

4. **Survival.** Provisions relating to breach notification, audit access, and HHS cooperation shall survive termination of this Agreement.

### Shyware Licensor Warranties

Shyware (Licensor) warrants to any Operator (Licensee) deploying **shystore-v1** that:

1. The two-list invariant write architecture structurally prevents materialisation of a participant-specific identity-payload join in canonical state under any valid state transition, as verified by the three-stack DPIA test suite (run 26369476939, 379/379 assertions on Stack 4, Stack 5, and Stack 6).
2. The sealer-key deletion path provides cryptographic unrecoverability of sealed PHI payloads, satisfying functional erasure requirements under GDPR Art. 17 and the HIPAA return/destruction obligation at 45 CFR §164.314(a)(2)(i).
3. The reconciling authority API is structurally non-enumerable: no bulk-scan endpoint exists; all retrieval is per-participant, identity-gated (Claim 59).
4. These warranties are based on the architecture of the shyware protocol as of run 26369476939. Shyware does not warrant compliance of operator-configured deployments that deviate from the **shystore-v1** reference shyconfig.

### General Provisions

1. **Amendment.** This Agreement may be amended only by a written instrument signed by authorised representatives of both parties. If required by changes in applicable law, the parties shall negotiate in good faith to amend this Agreement accordingly.
2. **Interpretation.** Any ambiguity in this Agreement shall be resolved in favour of a meaning that permits the Covered Entity to comply with the HIPAA Rules.
3. **No third-party beneficiaries.** Shyware (Licensor) is not a party to this Agreement. This Agreement does not create any rights in favour of Shyware against either party or vice versa. Shyware's role is as protocol licensor; the Operator is the Business Associate.
4. **Governing law.** This Agreement shall be governed by the laws of the jurisdiction specified in the underlying service agreement, except to the extent pre-empted by federal law (HIPAA/HITECH).
5. **Entire agreement.** This Agreement, together with the underlying service agreement and any applicable DPA or sub-processor schedules, constitutes the entire agreement between the parties with respect to PHI processing and supersedes any prior agreements on the subject.

| Covered Entity   | Business Associate |
|------------------|--------------------|
| Signature: _____ | Signature: _____   |
| Name: _____      | Name: _____        |
| Title: _____     | Title: _____       |
| Date: _____      | Date: _____        |